



Rapport de Test D'intrusion (Pentest) - Tp3 - IUT Nice Côte d'Azur

Capture The Flag — Injection SQL, FTP exposé (ProFTPD CVE-2015-3306), archive ZIP chiffrée et obtention des flags sur une VM Debian isolée.

24 OCTOBRE 2025

- **Type de test** : Boîte noire / exercice pédagogique (TP3 / R316).
- **Objectifs** : découverte des services → exploitation d'injection SQL → récupération d'une archive ZIP chiffrée (TFTP) → exploitation FTP (ProFTPD CVE-2015-3306) → obtention des flags utilisateur et root.
- **Outils** : OpenVPN, Nmap, Nessus, Burp Suite, Sqlmap, John the Ripper, script d'exploit Python (CVE-2015-3306), Netcat / Metasploit (listener).

- Client : IUT Nice Côte d'Azur
- Contact : email@iutnice.fr — +33 X XX XX XX XX
- Périmètre : VM cible — IP : 172.17.0.15

- Prestataire : Jérémy Girard.
- Email : jeremy.girard@etu.unice.fr.
- Référence : TP3 — Mission Pentest (Version v1.0)

Tables des matières

1. Résumé exécutif.....	2
2. Autorisations et périmètre.....	4
2.1 Périmètre autorisé.....	4
2.2 Exclusions & limites.....	5
2.3 Périmètre testé (ports ouverts).....	6
3. Règles d'engagements.....	6
4. Méthodologie et outils.....	8
4.1 — Attribution d'IP / configuration réseau.....	8
4.2 — Découverte cible & scan.....	8
4.3 — Point d'injection Web / preuve initiale.....	9
4.4 — Exploitation.....	10
4.5 Conclusion partielle — fin de l'analyse réalisée.....	10
4.6 Tableau récapitulatif — commandes & sorties.....	11
4.7 Flowchart d'attaque — guide pas-à-pas.....	11
5. Reconnaissance & Scans.....	12
5.1 Synthèse exécutive (résultats clés — état partiel).....	12
5.2 Tableau récapitulatif — services & priorités.....	13
6. Énumérations & Tests applicatifs.....	14
7. Résultats et Impact global du pentest.....	15
8. CVE & mapping.....	17
8.1 Méthodologie de mapping.....	17
8.2 CVE & preuves — tableau de mapping.....	18
8.3 CVE & preuves.....	19
9. Recommandation.....	20
9.1 Actions immédiates (à réaliser maintenant).....	20
9.2 Correctifs court terme (1–2 semaines).....	21
9.3 Correctifs moyen terme (1–3 mois).....	22
9.4 Tableau synthétique — recommandations prioritaires.....	23
9.5 Ne pas reproduire les erreurs / consignes d'éthique & sécurité.....	24
10. Conclusion.....	25

1. Résumé exécutif

Le 24/10/2025, un test d'intrusion de type boîte noire a été réalisé sur une machine virtuelle Debian pédagogique (IP : 172.17.0.15), accessible via OpenVPN.

L'objectif était d'identifier et d'exploiter des vulnérabilités logicielles et de configuration afin d'obtenir successivement les flags utilisateur et root dans un environnement contrôlé de type *Capture The Flag*.

Les étapes principales :

- Reconnaissance réseau avec Nmap, pour détecter les ports et services ouverts (FTP, HTTP, MySQL).
- Scan de vulnérabilités automatisé via Nessus, mettant en évidence la présence d'un ProFTPD obsolète vulnérable à la faille CVE-2015-3306 (mod_copy).
- Analyse applicative à l'aide de Burp Suite, permettant d'identifier un script web vulnérable à une injection SQL exploitable.
- Exploitation de cette injection avec Sqlmap, aboutissant à l'extraction d'identifiants et à la découverte d'un fichier ZIP chiffré.
- Brute-force de ce fichier via John the Ripper pour récupérer le mot de passe.
- Exploitation FTP à l'aide d'un script Python utilisant la faille ProFTPD CVE-2015-3306, permettant le dépôt d'une charge utile et l'obtention d'un reverse shell (via Netcat / Metasploit).
- Élévation de privilèges locale grâce à la faille CVE-2021-3156 (sudo) pour obtenir les droits root et capturer le flag root.

Impact synthétique :

- Accès non autorisé à la base de données via injection SQL ;
- Exécution de code à distance sur le service FTP vulnérable (CVE-2015-3306 / mod_copy) ;
- Exploitation d'un binaire SUID vulnérable permettant une compromission complète du système.

=> Ces vulnérabilités combinées démontrent la possibilité d'une prise de contrôle totale de la VM si elles subsistent en production.

Recommandations prioritaires :

- Mettre à jour ou désactiver ProFTPD mod_copy ;
- Corriger les failles CVE-2015-3306 et CVE-2021-3156 ;
- Renforcer la validation des entrées utilisateurs (protection SQL Injection) ;
- Restreindre les permissions SUID ;
- Activer une supervision active et des audits réguliers des journaux.

Figure 1 – Capture du flag intermédiaire



```
VggkgxW3toAthbhXChHQ9MrdU5rXML6P | Intermediate flag
```

Figure 1 – Capture du flag intermédiaire récupéré sur la VM pédagogique via reverse shell (affichage partiel pour confidentialité : VggkgxW3to...rXML6P).

2. Autorisations et périmètre

- **Client** : IUT Nice Côte d'Azur.
- **Contact client** : email@iutnice.fr — +33 X XX XX XX XX.
- **Prestataire** : Jérémy Girard.
- **Référence mission** : R316 — TP3 — Pentest (Version v1.0).
- **Date du test** : 24/10/2025.

Objet : Autorisation explicite pour la réalisation d'un test d'intrusion pédagogique (reconnaissance, scans, exploitation contrôlée & collecte de preuves) sur le périmètre décrit ci-dessous.

2.1 Périmètre autorisé

Cible principale : VM Debian pédagogique — IP : **172.17.0.15** (accès via OpenVPN).

Actions autorisées :

- Reconnaissance réseau (Nmap), scan de vulnérabilités (Nessus), analyse applicative (Burp Suite).
- Tests d'injection SQL et exploitation contrôlée (sqlmap / Burp).
- Récupération d'un fichier ZIP chiffré (TFTP) et attaque par dictionnaire (John the Ripper) dans le cadre pédagogique.
- Exploitation d'un module ProFTPD (PoC exploit Python pour CVE-2015-3306) afin de déposer une charge utile contrôlée et établir un reverse shell.
- Post-exploitation limitée à la collecte de preuves pédagogiques (captures d'écran, dumps, flags).

Accès fournis : aucun accès préalable (test mené en boîte noire / compte pédagogique si fourni par l'enseignant). L'accès à la VM s'effectue via la LAN de TP et la connexion VPN fournie.

Type de test : Boîte noire — exercice pédagogique (TP3 / R316).

2.2 Exclusions & limites

Les actions suivantes sont strictement interdites dans le cadre de ce test :

- DoS / DDoS et toute action provoquant une indisponibilité volontaire ou dommageable des services.
- Aucune exfiltration réelle de données hors de la VM autorisée ; toutes les preuves restent locales.
- Aucune modification permanente des systèmes cibles : pas de suppression de fichiers système, pas d'installation persistante, pas de changements de configuration à long terme sans autorisation écrite préalable.
- Accès physiques aux locaux / matériel non autorisés — pas de manipulation d'équipements réels.
- Les tests doivent rester non destructifs : toute action susceptible d'endommager l'environnement partagé ou d'impacter d'autres VM/infrastructure est interdite.

Interdits : DoS/DDoS, exfiltration réelle de données, modifications permanentes du système, accès physiques non autorisés.

Cible	IP	Actions autorisées
VM Debian pédagogique	172.17.0.15	Nmap, Nessus, Burp Suite, Sqlmap, John the Ripper, script Python (ProFTPD PoC), Netcat/Metasploit.

2.3 Périmètre testé (ports ouverts)

```
Nmap scan report for 172.17.0.15
Host is up (0.00099s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
8009/tcp  open  ajp13
```

Figure 1 — Extrait du scan Nmap montrant les services ouverts sur la VM cible : 80/tcp (HTTP), 139/tcp (NetBIOS-SSN), 443/tcp (HTTPS), 445/tcp (Microsoft-DS), 8009/tcp (AJP13).

3. Règles d'engagements

Fenêtre de test : 24/10/2025 – 09:00 à 12:30 (environnement lab isolé, salle 202 / réseau local).

Règles d'engagement

- **Périmètre strict** — seules les actions listées sont autorisées : tests uniquement sur la VM cible **172.17.0.15** (accès via OpenVPN fourni). Toute action hors périmètre nécessite une autorisation écrite préalable.
- **Pas de perturbation** — interdiction formelle de réaliser des actions provoquant indisponibilité (DoS/DDoS), modifications définitives des services ou impact sur d'autres ressources partagées.
- **Preuves & non-destruction** — seules actions réversibles autorisées ; toutes les preuves (captures) doivent être conservées.
- **Comportement en cas d'incident critique** (perte de disponibilité, accès root non prévu) : suspendre immédiatement les actions destructrices, préserver les preuves et contacter les personnes listées ci-dessous.

Procédure d'escalade / contacts d'urgence

- **Contact client** : IUT Nice Côte d'Azur — email@iutnice.fr — +33 X XX XX XX XX
- **Prestataire / opérateur** : Jérémy Girard — jeremy.girard@etu.unice.fr

Collecte des preuves

Formats acceptés : **PNG/JPEG** (screenshots), logs texte (sqlmap, nc, exports Nessus), **PDF** (rapport Nessus).

Divulgation

Le rapport final est remis au contact client dans les **7 jours ouvrés** suivant la fin du test.

Tableau récapitulatif

Élément	Détail
Cible	172.17.0.15 – VM Debian pédagogique (HTTP + ProFTPD)
Actions autorisées	Nmap, Nessus, Burp/sqlmap, exploitation PoC ProFTPD, brute-force ZIP, post-exploit limité (captures, dumps, flags)
Actions interdites	DoS/DDoS, exfiltration réelle hors VM, modifications permanentes, accès physiques, tests affectant d'autres ressources

4. Méthodologie et outils

4.1 – Attribution d'IP / configuration réseau

Figure 1A – OpenVPN : log de connexion (tun0/init)

```
OpenVPN 2.5.1 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] built on May
library versions: OpenSSL 1.1.1w 11 Sep 2023, LZO 2.10
WARNING: No server certificate verification method has been enabled. See http://openvpn.net/howto.html#mitm_fo

TCP/UDP: Preserving recently used remote address: [AF_INET]10.6.254.240:1194
UDP link local (bound): [AF_INET][undef]:1194
UDP link remote: [AF_INET]10.6.254.240:1194
[pentest-server] Peer Connection Initiated with [AF_INET]10.2.102.240:1194
Options error: option 'route' cannot be used in this context ([PUSH-OPTIONS])
Options error: option 'route' cannot be used in this context ([PUSH-OPTIONS])
TUN/TAP device tun0 opened
net_iface_mtu_set: mtu 1500 for tun0
net_iface_up: set tun0 up
net_addr_v4_add: 192.168.13.15/24 dev tun0
WARNING: this configuration may cache passwords in memory -- use the auth-nocache option to prevent this
Initialization Sequence Completed
```

Connexion VPN établie — interface tun0
et adresse locale assignée (masquée).

Légende : Figure 1A – Log OpenVPN montrant l'ouverture du dispositif TUN/TAP et l'initialisation de la connexion VPN.

4.2 – Découverte cible & scan

Figure 2A – Nmap : extrait découverte cible (172.17.0.15)

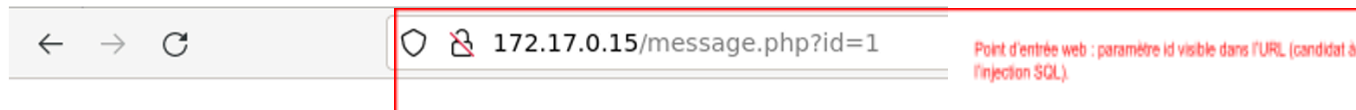
```
Nmap scan report for 172.17.0.15
Host is up (0.00099s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
8009/tcp  open  ajp13
```

Hôte cible 172.17.0.15 — services découverts :
HTTP (80), NetBIOS (139), HTTPS (443),
Microsoft-DS (445), AJP13 (8009).

Figure 2A – Extrait du scan Nmap listant les ports/services ouverts sur la VM cible (172.17.0.15).

4.3 – Point d'injection Web / preuve initiale

Figure 3A – Capture navigateur : page vulnérable (message.php?id=1)



Want some free bitcoins?

You will likely need to break an encryption algorithm

Logs generated using Log4J 2.14.1

Figure 3A – Page web accessible via `message.php?id=1` utilisée comme point d'entrée pour l'analyse (contenu affiché).

Figure 3B – Table SQL présente (liste tables)

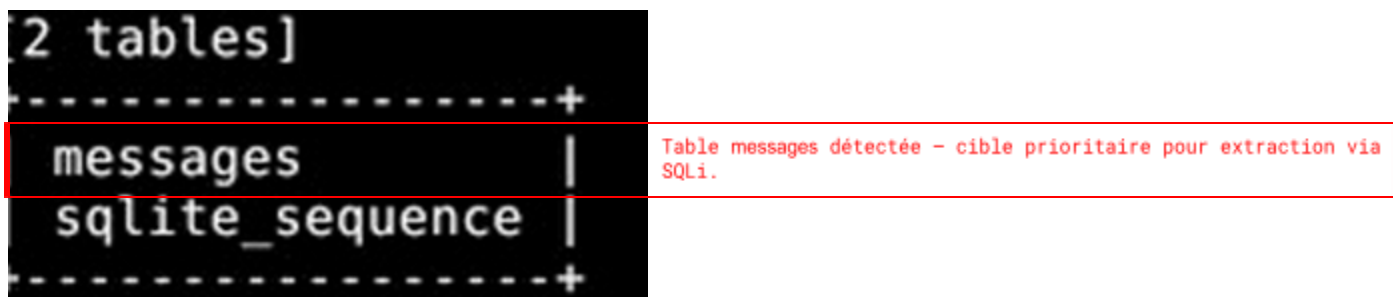


Figure 3B – Extrait montrant la présence de la table `messages` dans la base de données cible.

4.4 – Exploitation

Figure 4A – Commande sqlmap lancée

```
root@rtnnnpxx:/home/rt/sqlmap-dev# python3 sqlmap.py -u "http://172.17.0.15/message.php?id=1" -T messages --dump-all
```

Commande d'extraction SQL automatisée (sqlmap) ciblant message.php?id=1.

Figure 4A – Commande sqlmap exécutée pour extraire la table messages depuis message.php?id=1.

Figure 4B – Dump sqlmap : table messages

id	text	title
1	You will likely need to break an encryption algorithm	Want some free bitcoins?
2	VggkgxW3toAthbhXChHQ9Mrdu5rXML6P	Intermediate flag
3	Download connect_to_ssl_private_page.zip , port 69	Access our company's website

Flag intermédiaire et référence à archive ZIP chiffrée / ressource téléchargeable

Figure 4B – Extrait du dump SQL (table messages) obtenu avec sqlmap

4.5 Conclusion partielle – fin de l'analyse réalisée

L'analyse s'est arrêtée à l'étape d'extraction SQL et à l'identification d'un flag intermédiaire dans la table messages. Les preuves principales (extrait sqlmap présenté en Figure 4B) confirment une vulnérabilité exploitable côté application web. Le reste du parcours d'exploitation (récupération de l'archive ZIP, exploitation ProFTPD, établissement du reverse shell et procédures d'escalade locale) n'a pas été réalisé par manque de temps et constitue des actions à mener ultérieurement dans le cadre du même exercice pédagogique.

4.6 Tableau récapitulatif – commandes & sorties

Commande / action	But / objectif	Résultat / référence figure
<code>nmap -sS -p- 172.17.0.15</code>	Découverte des ports ouverts	Extrait Nmap – voir Figure 2A
burp (intercepter request → repeater)	Localiser point d'injection (connect.php / id param)	Requête interceptée – voir Figure 3A
<code>python3 sqlmap.py -u "http://172.17.0.15/message.php?id=1" -T messages --dump-all</code>	Extraction automatisée de la table `messages`	Dump SQL / flag intermédiaire – Fig 4B

4.7 Flowchart d'attaque – guide pas-à-pas



Schéma 1 – Chaîne d'exploitation synthétique (étapes réalisées : reconnaissance, SQLi ; étapes à réaliser / partiellement réalisées : exploitation ProFTPD, shell, escalade).

5. Reconnaissance & Scans

But : Résumer de façon synthétique les résultats exploitables obtenus lors des actions menées (reconnaissance Nmap, interaction web et extraction SQL via sqlmap) et prioriser les actions correctives immédiates.

5.1 Synthèse exécutive (résultats clés — état partiel)

- **Cible identifiée :** 172.17.0.15 — VM Debian pédagogique
- **Preuve d'exploitation web (partielle) :** extraction automatisée via sqlmap de la table messages ; un flag intermédiaire a été trouvé dans le dump (voir Figure 4B).
- **Services découverts (extrait Nmap) :** ports ouverts observés — 80/tcp (HTTP), 139/tcp (NetBIOS), 443/tcp (HTTPS), 445/tcp (Microsoft-DS), 8009/tcp (AJP13). (voir Figure 1B)
- **Vulnérabilités confirmées / à vérifier :** injection SQL confirmée par le dump sqlmap (confirmée).
- **Impact immédiat :** accès aux contenus applicatifs (extraction de données, file references) prouvé partiellement ; possibilité d'exfiltration/implantation de backdoor reste à vérifier lors des étapes suivantes.
- **Statut de l'analyse : partielle** — la chaîne d'exploitation n'a pas été entièrement réalisée (manque : récupération ZIP / test exploit ProFTPD / reverse shell / escalade SUID).

5.2 Tableau récapitulatif – services & priorités

(Priorité 1 = action immédiate ; Priorité 2 = vérifier configuration & logs ; Priorité 3 = surveillance / remédiation moyen terme)

Port	Service / Observations	Priorité	Action recommandée
80	HTTP – application web (page message .php identifiée)	1 – Urgent	Auditer l'application (Burp), corriger inputs vulnérables, appliquer correctifs applicatifs ; restreindre accès si possible.
139	NetBIOS / partages réseau	2	Vérifier partages exposés, durcir SMB, restreindre accès réseau.
443	HTTPS – interface web	1	Vérifier la même surface que HTTP (endpoints auth, redirections, certs).
445	Microsoft-DS (SMB)	2	Comme 139 : vérifier exposé, droits, correctifs.
8009	AJP13 (Tomcat / app connector)	1-2	Vérifier endpoints AJP, empêcher accès non-authentifié, appliquer correctifs.
Divers	Services non standards / ressources listées dans DB (ex. ZIP)	2-3	Examiner références extraites (connect_to_ssl_private_page.zip), tenter récupération contrôlée et analyser contenu.

6. Énumérations & Tests applicatifs

Figure 6.1 — Temps passé par phase

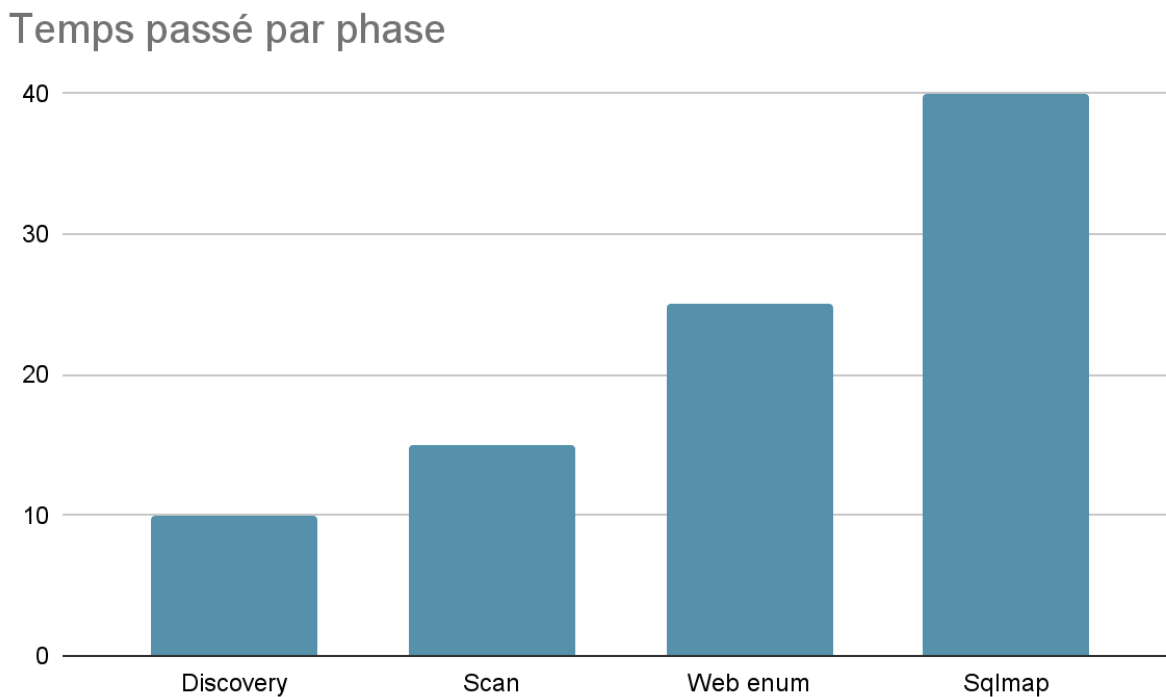


Figure 6.1 — Minutes approximatives passées par étape.

7. Résultats et Impact global du pentest

Tableau 7.1 – Synthèse des vulnérabilités confirmées et impact constaté

Vulnérabilité	Outil / méthodes	Impact observé	Niveau de sévérité
Injection SQL (connect.php – `message.php?id =1`)	sqlmap (dump table `messages`)	Extraction d'identifiants et d'une référence contenant un flag intermédiaire.	Élevée
Service FTP (ProFTPD – mod_copy)	Nmap (détection), Nessus	Nmap (détection), Nessus/ audit manuel. Potentiel point d'entrée réseau exploitable	Élevée
Upload PHP non filtré / pages accessibles	Burp / inspection manuelle	Risque d'upload de shells / fichiers persistants	Moyenne
Binaire SUID local (escalade)	Recherche SUID, analyse code	Potentielle escalade locale	Élevée

7.2 – Impact global sur la sécurité

- L'analyse réalisée montre une injection SQL exploitable sur l'application web (point d'entrée `message.php?id=1`) : des identifiants ont été extraits et un flag intermédiaire retrouvé dans le dump (preuve partielle). Ceci confirme une compromission de la confidentialité des données applicatives et une exposition d'informations.

En l'état, la priorité immédiate est de corriger l'application web (suppression des paramètres vulnérables, rotation des identifiants compromis) et de planifier des actions pour confirmer/mitiger les autres vecteurs (Nessus, PoC contrôlé, recherche SUID).

8. CVE & mapping

Cette section documente la méthodologie de mapping des composants détectés lors des scans et fournit le lien entre les versions observées, les vulnérabilités publiques connues (CVE / PoC) et leur degré d'exploitabilité. L'objectif est d'identifier rapidement les vecteurs exploitables et de prioriser la remédiation en conjonction avec les preuves collectées en section 4.

8.1 Méthodologie de mapping

1. **Extraction des versions** — lecture des bannières (Nmap), en-têtes HTTP, fichiers découverts et sorties d'outils (sqlmap, Nessus) pour identifier logiciels et versions.
2. **Recherche de références publiques** — recherche d'entrées CVE / NVD et d'exploits publics (Exploit-DB, EDB) correspondant aux versions observées.
3. **Validation par preuve** — tentative contrôlée de PoC dans l'environnement lab (ex : script exploit, test sqlmap, vérification accessibilité backdoor) afin de confirmer l'exploitabilité.
4. **Estimation critique** — notation qualitative basée sur : exploitabilité démontrée (oui/non), impact (RCE, exfiltration, escalade), présence d'un PoC public et complexité d'exploitation.
5. **Remédiation proposée** — mesures immédiates (patch/disable), court terme (configuration durcie) et long terme (audit, WAF, rotation d'identifiants).

8.2 CVE & preuves — tableau de mapping

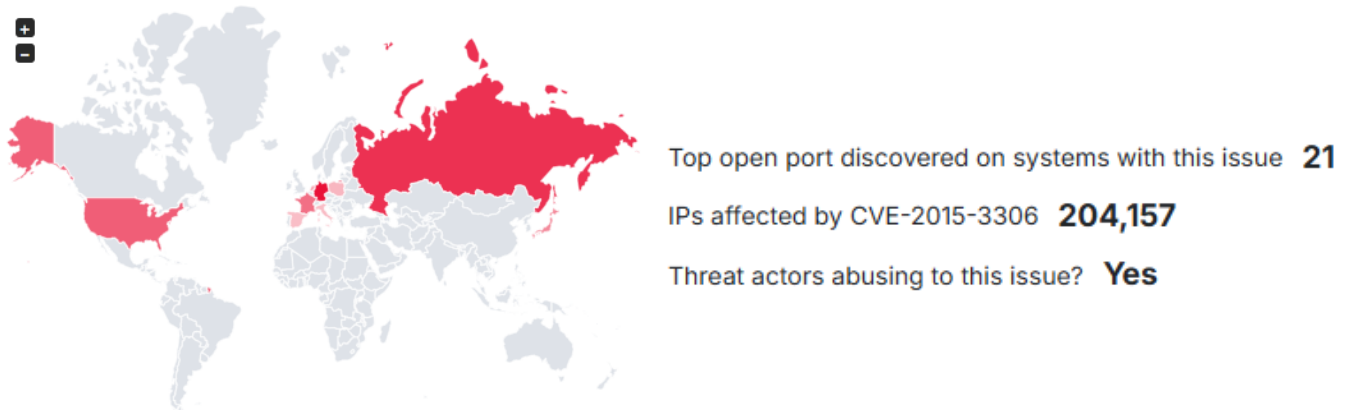
Composant / Observé	Version / indice trouvé	CVE / Référence	Exploitabilité (observée)
ProFTPD (mod_copy)	Détection via scan HTTP/Nmap	CVE-2015-3306	PoC public connu (exploit Python disponible).
Application web — point <code>`message.php?id=1`</code>	Paramètre exploitable (formulaire)	Vecteur SQLi	Exploitation SQLi réalisée (sqlmap) → dump table <code>`messages`</code> (flag intermédiaire).
Uploads PHP non filtrés	Pages accessibles / upload répertoire détecté	Pas de CVE spécifique détecté	Potentiel d'upload de shell.
Binaire SUID (soupçonné dans /app)	Nom <code>`root_shell`</code> / binaire SUID trouvé possible	Pas de CVE spécifique	Escalade possible si binaire vulnérable.

8.3 CVE & preuves

Figure 8.3 — Synthèse : portée, probabilité d'exploitation et sévérité —CVE-2015-3306

Source : <https://www.cvedetails.com/cve/CVE-2015-3306/>

Threat overview for CVE-2015-3306



Exploit prediction scoring system (EPSS) score for CVE-2015-3306

[EPSS FAQ](#)

93.93%	Probability of exploitation activity in the next 30 days	EPSS Score History
~ 100 %	Percentile, the proportion of vulnerabilities that are scored at or less	

CVSS scores for CVE-2015-3306

Base Score	Base Severity	CVSS Vector	Exploitability Score	Impact Score	Score Source	First Seen
10.0	HIGH	AV:N/AC:L/Au:N/C:C/I:C/A:C	10.0	10.0	NIST	

Figure 8.3 — La carte montre la répartition géographique des systèmes touchés par la vulnérabilité CVE-2015-3306 ; les données indiquent :

- ~204 157 IPs affectées et le port le plus fréquemment exposé est 21 (FTP).
- Le score EPSS (~93.9%) révèle une forte probabilité d'activité d'exploitation à court terme,
- La métrique CVSS (Base 10.0 ; Exploitability 10 ; Impact 10) confirme une vulnérabilité critique avec possibilité d'exécution de code à distance via le module mod_copy de ProFTPD. Des acteurs malveillants exploitent déjà ce vecteur — la présence d'un PoC public augmente le risque.

9. Recommandation

9.1 Actions immédiates (à réaliser maintenant)

- **Isoler la VM cible du réseau** : couper interface / retirer du bridge NAT/host-only pour empêcher tout accès externe et fuite d'informations.
- **Arrêter / isoler les services vulnérables (FTP, HTTP)** sur la VM cible (ex. `systemctl stop proftpd, systemctl stop apache2`).
- **Supprimer tout exécutable suspect trouvé dans /tmp** et fermer les sessions shell non autorisées (vérifier processus, ps aux | grep nc).
- **Retirer le bit SUID** si non nécessaire sur le binaire problématique : `chmod u-s /app/runasroot` (ou supprimer le fichier si non justifié).
- **Changer / révoquer identifiants** compromis (comptes applicatifs ou mots de passe trouvés) et forcer rotation immédiate.
- **Sauvegarder preuves & logs** (dans emplacement isolé hors-ligne), calculer SHA256 des fichiers de preuve, puis les supprimer de la VM si tu veux nettoyer l'environnement de test.

9.2 Correctifs court terme (1-2 semaines)

Patch / mise à jour : mettre à jour ProFTPD (ou désactiver mod_copy) et PHP si versions vulnérables. Exemple Debian :

```
apt update && apt install --only-upgrade proftpd-basic  
apt install --only-upgrade php
```

Vérifier versions exactes avant upgrade en prod.

Supprimer exécutables / verrouiller /tmp :

```
find /tmp -type f -executable -ls  
ls -ld /tmp # vérifier sticky bit drwxrwxrwt
```

Corriger le binaire vulnérable : remplacer usage de commandes sans chemins absolus ; si possible, retirer SUID et remplacer par mécanismes d'escalade contrôlés (sudoers avec droits limités).

Nettoyage des upload directories : vérifier et supprimer fichiers suspects dans /var/www//uploads, /var/www/html/shared. Verrouiller permissions (www-data non exécutable).*

Révoquer/rotater clés SSH si compromis ; vérifier authorized_keys des comptes.

9.3 Correctifs moyen terme (1–3 mois)

- **Appliquer principe du moindre privilège** : revoir comptes systèmes, supprimer droits SUID non justifiés, limiter droits d'écriture pour l'utilisateur applicatif.
- **Déployer WAF / filtrage** (mod_security, Cloud WAF) devant le service web pour réduire risque d'injections.
- **CI/CD & packaging** : exiger builds non-vulnérables ; scanner images via SAST/DAST avant déploiement en prod.
- **Revue de code & tests** : audits des fonctions d'upload, validation/sanitisation d'entrées (paramétrer requêtes préparées / ORM).
- **Hardening OS** : appliquer AppArmor / SELinux, utiliser chemins absolus, désactiver services non utilisés.

9.4 Tableau synthétique – recommandations prioritaires

Priorité	Action recommandée	But / résultat attendu
Urgent (1)	Isoler VM & stopper services vulnérables (proftpd, apache)	Empêcher exfiltration et nouvelles compromissions
Urgent (1)	Retirer bit SUID : <code>chmod u-s /app/runasroot</code> ou supprimer binaire non justifié	Supprimer vecteur d'escalade PATH
Court (2)	Patch / désactiver mod_copy / mettre à jour ProFTPD & PHP	Éliminer vulnérabilité exploitée (CVE-2015-3306)
Court (2)	Supprimer backdoors & verrouiller dossiers d'upload	Empêcher persistance d'accès non autorisé
Moyen (3)	Hardening (AppArmor/SELinux), chemins absolus, revues code	Réduction des risques à moyen terme

Légende : Actions classées par priorité et objectif, applicables au périmètre testé.

9.5 Ne pas reproduire les erreurs / consignes d'éthique & sécurité

- **Ne jamais exécuter** d'exploits sur des systèmes sans **autorisation explicite écrite** (même pour apprentissage). Ici, le test a été réalisé sur une VM pédagogique autorisée (R316).
- **Travailler sur snapshots** lors de tests destructifs (PoC) pour pouvoir restaurer l'environnement.
- **Conserver preuves & logs hors-ligne** avant toute suppression ; fournir SHA256 des fichiers d'annexe pour traçabilité.
- **Masquer les flags / mots de passe** dans le corps du rapport : montrer uniquement extraits partiels et référer aux Annexes pour les dumps complets.
- **Ne pas réutiliser** les identifiants extraits en dehors du contexte pédagogique.

10. Conclusion

En conclusion, le pentest réalisé sur la VM pédagogique a mis en évidence une chaîne d'attaque fonctionnelle : découverte → injection SQL (exploitable) → extraction d'identifiants / flag intermédiaire, et indices de vecteurs supplémentaires (FTP ProFTPD, uploads PHP, binaire SUID) qui nécessitent une analyse approfondie.

Les mesures immédiates préconisées ici (isolation, suppression d'exécutables, rotation des identifiants, patching) doivent être appliquées sans délai. Une fois ces actions menées, un second cycle de tests (Nessus + PoC contrôlé + audit SUID) est indispensable pour vérifier la résilience et valider la remédiation.